

Safeguard 8.5: Collect Detailed Audit Logs

Asset Type:	Data	Security Function:	Detect	IG2	IG3
-------------	------	--------------------	--------	-----	-----

Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.

Safeguard 8.6: Collect DNS Query Audit Logs

Asset Type:	Data	Security Function:	Detect	IG2	IG3
-------------	------	--------------------	--------	-----	-----

Collect DNS query audit logs on enterprise assets, where appropriate and supported.

Safeguard 8.7: Collect URL Request Audit Logs

Asset Type:	Data	Security Function:	Detect	IG2	IG3
-------------	------	--------------------	--------	-----	-----

Collect URL request audit logs on enterprise assets, where appropriate and supported.

Safeguard 8.8: Collect Command-Line Audit Logs

Asset Type:	Data	Security Function:	Detect	IG2	IG3
-------------	------	--------------------	--------	-----	-----

Collect command-line audit logs. Example implementations include collecting audit logs from PowerShell®, BASH™, and remote administrative terminals.

Safeguard 8.9: Centralize Audit Logs

Asset Type:	Data	Security Function:	Detect	IG2	IG3
-------------	------	--------------------	--------	-----	-----

Centralize, to the extent possible, audit log collection and retention across enterprise assets in accordance with the documented audit log management process. Example implementations primarily include leveraging a SIEM tool to centralize multiple log sources.

Safeguard 8.10: Retain Audit Logs

Asset Type:	Data	Security Function:	Protect	IG2	IG3
-------------	------	--------------------	---------	-----	-----

Retain audit logs across enterprise assets for a minimum of 90 days.

Safeguard 8.11: Conduct Audit Log Reviews

Asset Type: Data	Security Function: Detect	IG2	IG3
------------------	---------------------------	-----	-----

Conduct reviews of audit logs to detect anomalies or abnormal events that could indicate a potential threat. Conduct reviews on a weekly, or more frequent, basis.

Safeguard 8.12: Collect Service Provider Logs

Asset Type: Data	Security Function: Detect	IG3
------------------	---------------------------	-----

Collect service provider logs, where supported. Example implementations include collecting authentication and authorization events, data creation and disposal events, and user management events.

CONTROL 9

Email and Web Browser Protections

Safeguards: 7	IG1: 2/7	IG2: 6/7	IG3: 7/7
---------------	----------	----------	----------

Overview

Improve protections and detections of threats from email and web vectors, as these are opportunities for attackers to manipulate human behavior through direct engagement.

Why is this Control critical?

Web browsers and email clients are very common points of entry for attackers because of their direct interaction with users inside an enterprise. Content can be crafted to entice or spoof users into disclosing credentials, providing sensitive data, or providing an open channel to allow attackers to gain access, thus increasing risk to the enterprise. Since email and web are the main means that users interact with external and untrusted users and environments, these are prime targets for both malicious code and social engineering. Additionally, as enterprises move to web-based email, or mobile email access, users no longer use traditional full-featured email clients, which provide embedded security controls like connection encryption, strong authentication, and phishing reporting buttons.

Procedures and tools

Web Browser

Cybercriminals can exploit web browsers in multiple ways. If they have access to exploits of vulnerable browsers, they can craft malicious webpages that can exploit those vulnerabilities when browsed with an insecure, or unpatched, browser. Alternatively, they can try to target any number of common web browser third-party plugins that may allow them to hook into the browser or even directly into the operating system or application. These plugins, much like any other software within an environment, need to be reviewed for vulnerabilities, kept up-to-date with latest patches or versions, and controlled. Many come from untrusted sources, and some are even written to be malicious. Therefore, it is best to prevent users from intentionally or unintentionally installing malware that might be hiding in some of these plugins, extensions, and add-ons. Simple configuration updates to the browser can make it much harder for malware to get installed through reducing the ability of installing add-ons/plugins/extensions and preventing specific types of content from automatically executing.

Most popular browsers employ a database of phishing and/or malware sites to protect against the most common threats. A best practice is to enable these content filters and turn on the pop-up blockers. Pop-ups are not only annoying; they can also host embedded malware directly or lure users into clicking links using social engineering tricks. To help enforce blocking of known malicious domains, also consider subscribing to DNS filtering services to block attempts to access these websites at the network level.

Email

Email represents one the most interactive ways humans work with enterprise assets; training and encouraging the right behavior is just as important as the technical settings. Email is the most common threat vector against enterprises through tactics such as phishing and Business Email Compromise (BEC).

Using a spam-filtering tool and malware scanning at the email gateway reduces the number of malicious emails and attachments that come into the enterprise's network. Initiating Domain-based Message Authentication, Reporting, and Conformance (DMARC) helps reduce spam and phishing activities. Installing an encryption tool to secure email and communications adds another layer of user and network-based security. In addition to blocking based on the sender, it is also worthwhile to only allow certain file types that users need for their jobs. This will require coordination with different business units to understand what types of files they receive via email to ensure that there is not an interruption to their processes.

Since phishing email techniques are ever evolving to get past spam filter rules, it is important to train users on how to identify phishing, and to notify IT Security when they see one. There are many platforms that perform phishing tests against users to help educate them on different examples, and track their improvement over time. Crowd-sourcing this knowledge into notifying IT Security teams of phishing helps improve the protections and detections of email-based threats.

Safeguards

Safeguard 9.1: Ensure Use of Only Fully Supported Browsers and Email Clients

Asset Type: **Software**

Security Function: **Protect**

IG1

IG2

IG3

Ensure only fully supported browsers and email clients are allowed to execute in the enterprise, only using the latest version of browsers and email clients provided through the vendor.

Safeguard 9.2: Use DNS Filtering Services

Asset Type: **Devices**

Security Function: **Protect**

IG1

IG2

IG3

Use DNS filtering services on all end-user devices, including remote and on-premises assets, to block access to known malicious domains.

Safeguard 9.3: Maintain and Enforce Network-Based URL Filters

Asset Type: **Network**

Security Function: **Protect**

IG2

IG3

Enforce and update network-based URL filters to limit an enterprise asset from connecting to potentially malicious or unapproved websites. Example implementations include category-based filtering, reputation-based filtering, or through the use of block lists. Enforce filters for all enterprise assets.

Safeguard 9.4: Restrict Unnecessary or Unauthorized Browser and Email Client Extensions

Asset Type: **Software**

Security Function: **Protect**

IG2

IG3

Restrict, either through uninstalling or disabling, any unauthorized or unnecessary browser or email client plugins, extensions, and add-on applications.

Safeguard 9.5: Implement DMARC

Asset Type: **Network**

Security Function: **Protect**

IG2

IG3

To lower the chance of spoofed or modified emails from valid domains, implement DMARC policy and verification, starting with implementing the Sender Policy Framework (SPF) and the DomainKeys Identified Mail (DKIM) standards.

Safeguard 9.6: Block Unnecessary File Types

Asset Type:	Network	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Block unnecessary file types attempting to enter the enterprise’s email gateway.

Safeguard 9.7: Deploy and Maintain Email Server Anti-Malware Protections

Asset Type:	Network	Security Function:	Protect	IG3
-------------	---------	--------------------	---------	-----

Deploy and maintain email server anti-malware protections, such as attachment scanning and/or sandboxing.

CONTROL 10

Malware Defenses

Safeguards: 7	IG1: 3/7	IG2: 7/7	IG3: 7/7
---------------	----------	----------	----------

Overview

Prevent or control the installation, spread, and execution of malicious applications, code, or scripts on enterprise assets.

Why is this Control critical?

Malicious software (sometimes categorized as viruses or Trojans) is an integral and dangerous aspect of internet threats. They can have many purposes, from capturing credentials, stealing data, identifying other targets within the network, and encrypting or destroying data. Malware is ever-evolving and adaptive, as modern variants leverage machine learning techniques.

Malware enters an enterprise through vulnerabilities within the enterprise on end-user devices, email attachments, webpages, cloud services, mobile devices, and removable media. Malware often relies on insecure end-user behavior, such as clicking links, opening attachments, installing software or profiles, or inserting Universal Serial Bus (USB) flash drives. Modern malware is designed to avoid, deceive, or disable defenses.

Malware defenses must be able to operate in this dynamic environment through automation, timely and rapid updating, and integration with other processes like vulnerability management and incident response. They must be deployed at all possible entry points and enterprise assets to detect, prevent spread, or control the execution of malicious software or code.

Procedures and tools

Effective malware protection includes traditional endpoint malware prevention and detection suites. To ensure malware IOCs are up-to-date, enterprises can receive automated updates from the vendor to enrich other vulnerability or threat data. These tools are best managed centrally to provide consistency across the infrastructure.

Being able to block or identify malware is only part of this CIS Control; there is also a focus on centrally collecting the logs to support alerting, identification, and incident response. As malicious actors continue to develop their methodologies, many taking a “living-off-the-land” (LotL) approach to minimize the likelihood of being caught. This approach refers to attacker behavior that uses tools or features that already exist in the target environment. Enabling logging, as per the Safeguards in CIS Control 8, will make it significantly easier for the enterprise to follow the events to understand what happened and why it happened.

CIS provides a series of guides to understand how the CIS Controls apply to the most common living-off-the-land techniques:
<https://www.cisecurity.org/controls/resources?crc=minimize-your-threats>

Safeguards

Safeguard 10.1: Deploy and Maintain Anti-Malware Software

Asset Type:	Devices	Security Function:	Detect	IG1	IG2	IG3
-------------	---------	--------------------	--------	-----	-----	-----

Deploy and maintain anti-malware software on all enterprise assets.

Safeguard 10.2: Configure Automatic Anti-Malware Signature Updates

Asset Type:	Devices	Security Function:	Protect	IG1	IG2	IG3
-------------	---------	--------------------	---------	-----	-----	-----

Configure automatic updates for anti-malware signature files on all enterprise assets.

Safeguard 10.3: Disable Autorun and Autoplay for Removable Media

Asset Type:	Devices	Security Function:	Protect	IG1	IG2	IG3
-------------	---------	--------------------	---------	-----	-----	-----

Disable autorun and autoplay auto-execute functionality for removable media.

Safeguard 10.4: Configure Automatic Anti-Malware Scanning of Removable Media

Asset Type:	Devices	Security Function:	Detect	IG2	IG3
-------------	---------	--------------------	--------	-----	-----

Configure anti-malware software to automatically scan removable media.

Safeguard 10.5: Enable Anti-Exploitation Features

Asset Type:	Devices	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.

Safeguard 10.6: Centrally Manage Anti-Malware Software

Asset Type:	Devices	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Centrally manage anti-malware software.

Safeguard 10.7: Use Behavior-Based Anti-Malware Software

Asset Type:	Devices	Security Function:	Detect	IG2	IG3
-------------	---------	--------------------	--------	-----	-----

Use behavior-based anti-malware software.

CONTROL 11

Data Recovery

Safeguards: 5	IG1: 4/5	IG2: 5/5	IG3: 5/5
---------------	----------	----------	----------

Overview

Establish and maintain data recovery practices sufficient to restore in-scope enterprise assets to a pre-incident and trusted state.

Why is this Control critical?

In the cybersecurity triad—Confidentiality, Integrity, and Availability (CIA)—the availability of data is, in some cases, more critical than its confidentiality. Enterprises need many types of data to make business decisions, and when that data is not available or is untrusted, then it could impact the enterprise. An easy example is weather information to a transportation enterprise.

When attackers compromise assets, they make changes to configurations, add accounts, and often add software or scripts. These changes are not always easy to identify, as attackers might have corrupted or replaced trusted applications with malicious versions, or the changes might appear to be standard-looking account names. Configuration changes can include adding or changing registry entries, opening ports, turning off security services, deleting logs, or other malicious actions that make a system insecure. These actions do not have to be malicious; human error can cause each of these as well. Therefore, it is important to have an ability to have recent backups or mirrors to recover enterprise assets and data back to a known trusted state.

There has been an exponential rise in ransomware over the last few years. It is not a new threat, though it has become more commercialized and organized as a reliable method for attackers to make money. If an attacker encrypts an enterprise’s data and demands ransom for its restoration, having a recent backup to recover to a known, trusted state can be helpful. However, as ransomware has evolved, it has also become an extortion technique, where data is exfiltrated before being encrypted, and the attacker asks for payment to restore the enterprise’s data, as well as to keep it from being sold or publicized. In this case, restoration would only solve the issue of restoring systems to a trusted state and continuing operations. Leveraging the guidance within the CIS Controls will help reduce the risk of ransomware through improved cyber hygiene, as attackers usually use older or basic exploits on insecure systems.